

Privacidade no Processamento Estatístico de Dados

Mestrado em Direito e Informática

Privacidade e Protecção de Dados Pessoais - 2019/2020

Privacy-Enhancing Technologies (PETs)

- Cibersegurança foca-se na proteção de dados contra acesso
- PETs focam-se em permitir derivar resultados úteis dos dados sem ser necessário dar acesso aos mesmos
- Termo muito lato, desde colocar fita cola numa câmara a técnicas criptográficas avançadas
- Potencial de incentivar maior partilha de dados de forma privada e confiável ou alterar o atual modelo de economia de dados

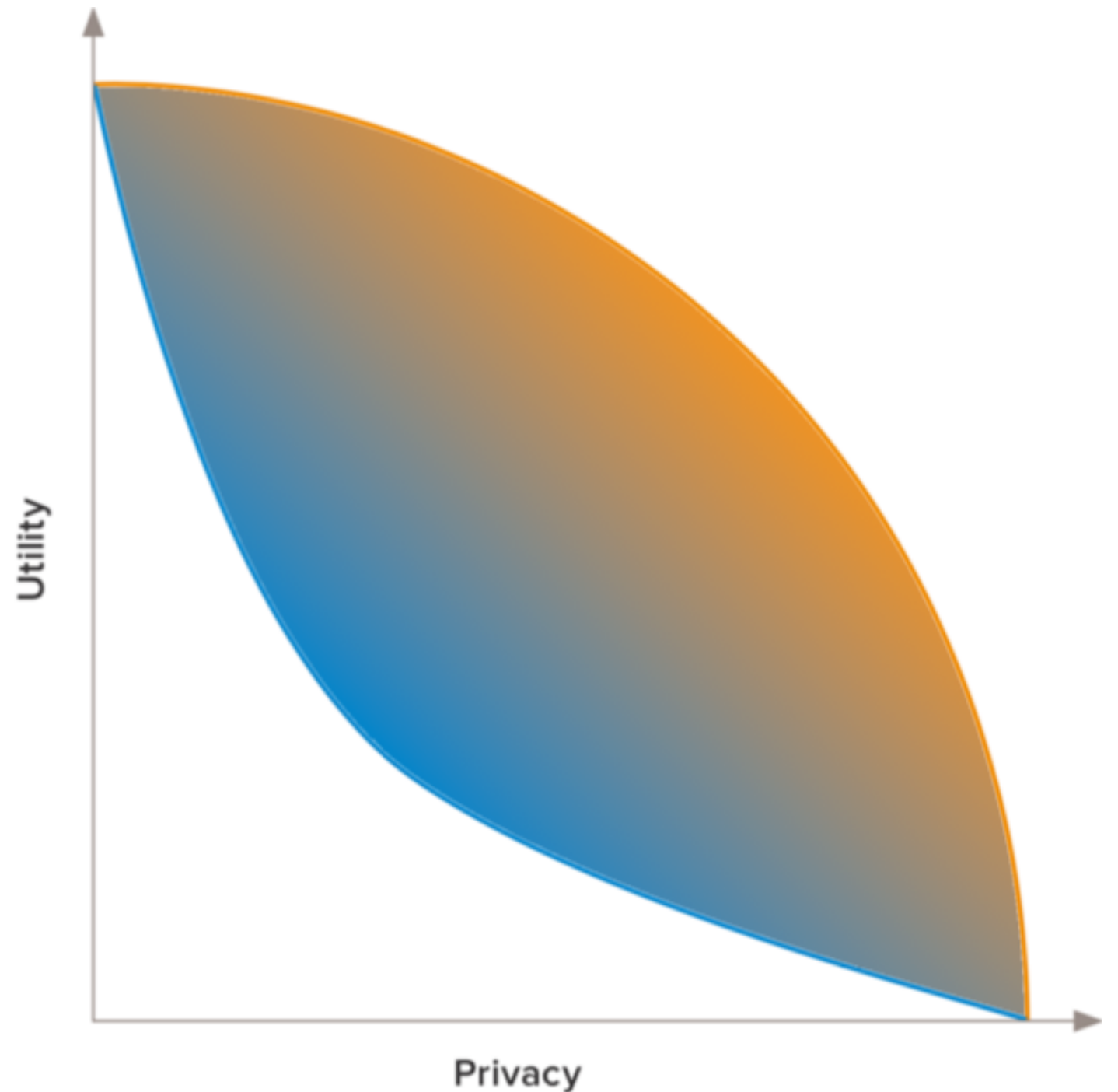


PETs: Processamento de Dados

- Diferentes tipos de processamento de dados:
 - Privacidade no processamento estatístico de dados (e.g. analisar trends no Facebook)
 - Privacidade na delegação de computação para a cloud (e.g. utilizar um serviço online que converte ficheiros Word em PDF)
 - Privacidade na análise conjunta de dados na posse de organizações distintas (e.g. cruzamento de dados financeiros entre diferentes países)
 - Descentralização de serviços dependentes de dados pessoais (e.g. coletivos de utilizadores podem gerir e vender os seus dados)
 - etc

PETs: Trade-offs

- Diferentes noções de utilidade, e.g.:
 - Tempo
 - Computação
 - Precisão
 - Dinheiro



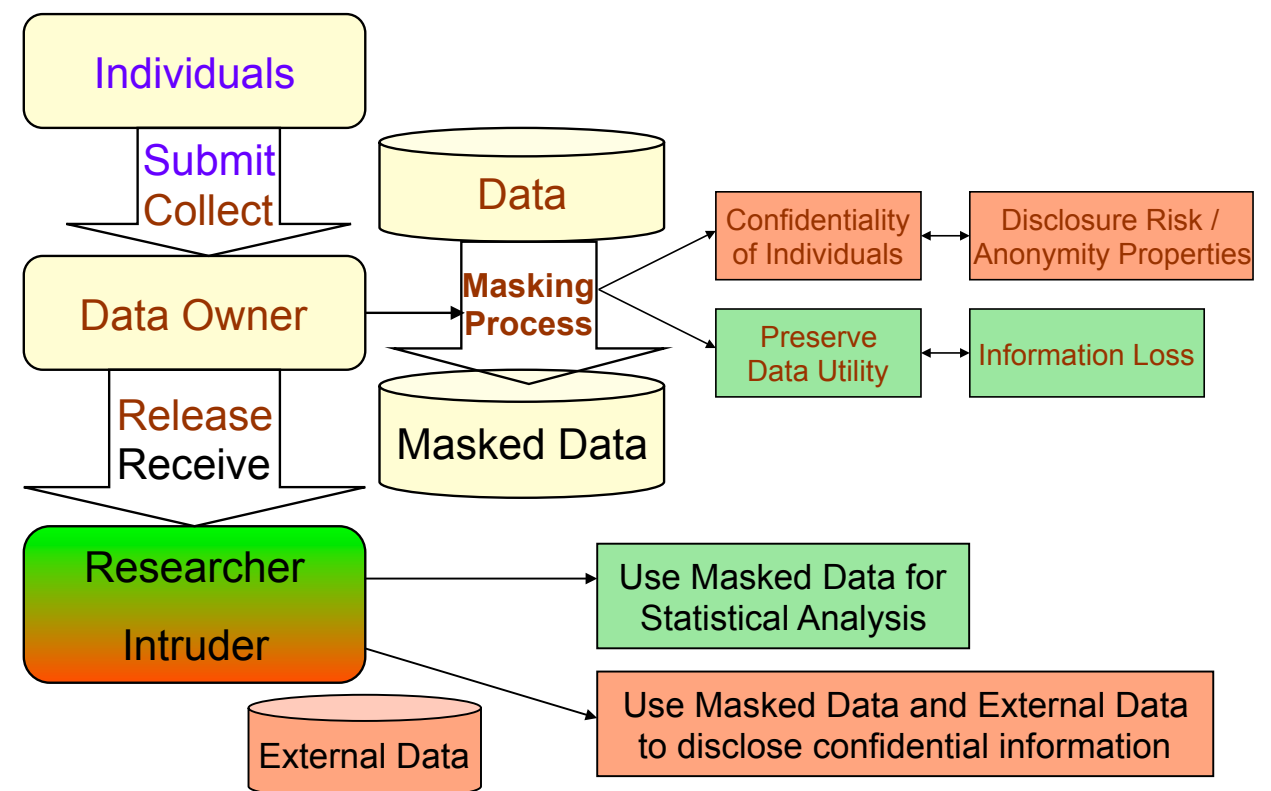
Processamento Estatístico de Dados

- Análise estatística de dados é uma ferramenta importante na identificação de tendências e no suporte à tomada de decisão
- Essa importância é atestada pelo enquadramento dado aos organismos com essa competência (e.g. INE, Pordata, Censos)
- Genericamente, pode-se afirmar que o acesso a bases de informação estatística é socialmente desejável (e.g. no suporte à investigação científica; prospecção de mercado; tendências; etc.)
- Mas interessa garantir que a análise dos dados não compromete a privacidade dos indivíduos que contribuem para essas bases de dados

Cenário Considerado

- Admite-se que numa Base de Dados (BD) se armazenam uma colecção de **atributos** referentes a um conjunto de **indivíduos**
- Problema: *Disclosure Control* — tratamento dos dados por forma a impedir que outras partes tenham acesso a informação privada contida nos dados
- Tipos de violação de privacidade:
 - Identity disclosure — identificação de uma entidade (pessoa ou instituição)
 - Attribute disclosure — descoberta de um dado confidencial sobre um indivíduo

Sex	Blood	...	HIV
F	B	...	Y
M	A	...	N
M	O	...	N
M	O	...	Y
F	A	...	N
M	B	...	Y



Conceitos Legais

- Pseudonimização: *data that can no longer be attributed to a specific data subject without the use of additional information* (Recital 26 GDPR)
 - *De cariz reversível*
- Anonimização: *data rendered anonymous in such a way that the data subject is not or no longer identifiable.* (Recital 26 GDPR)
 - *De cariz irreversível*
- Há diferenças práticas?
- “*Identificar um sujeito*” não tem nenhum significado técnico ou formal...

Anonimização usando agregação

- Ana é professora e quer calcular uma estatística representativa dos alunos
- Ana publica: “*O João Silva é um aluno e tem média de 14 valores*”
- E se... um novo aluno chamado João Silva chega à escola no mês seguinte?
- Privacidade do João Silva verdadeiro não foi violada

Anonimização usando agregação

- Ana publica em Janeiro: “*A escola tem 3005 alunos, dos quais 202 recebem apoio social*”
- Rui publica em Março: “*Na escola, 203 alunos numa amostra de 3006 recebem apoio social*”
- Eva descobre: “*Se o João Silva entrou na escola em Fevereiro, provavelmente recebe apoio social*”
- Perguntas sucessivas podem violar privacidade

Anonimização de atributos identificadores

- **Atributos Identificadores:** atributos que permitem associar os dados do registo a um indivíduo concreto
- Uma estratégia simples de anonimização dos dados consiste em remover/ofuscar todos a atributos identificadores

Initial Microdata						Masked Microdata			
Name	SSN	Age	Zip	Diagnosis	Income	Age	Zip	Diagnosis	Income
Alice	123456789	44	48202	AIDS	17,000	44	48202	AIDS	17,000
Bob	323232323	44	48202	AIDS	68,000	44	48202	AIDS	68,000
Charley	232345656	44	48201	Asthma	80,000	44	48201	Asthma	80,000
Dave	333333333	55	48310	Asthma	55,000	55	48310	Asthma	55,000
Eva	666666666	55	48310	Diabetes	23,000	55	48310	Diabetes	23,000

Data Owner

Anonimização de atributos identificadores

- A possibilidade do intruso poder cruzar dados “informação externa” pode comprometer a privacidade dos dados anonimizados
- L. Sweeney (MIT, 1998) mostrou como aceder ao registo médico do governador do estado de Massachusetts cruzando informação da seguradora com o caderno eleitoral da cidade onde habitava.

Initial Microdata

Name	SSN	Age	Zip	Diagnosis	Income
Alice	123456789	44	48202	AIDS	17,000
Bob	323232323	44	48202	AIDS	68,000
Charley	232345656	44	48201	Asthma	80,000
Dave	333333333	55	48310	Asthma	55,000
Eva	666666666	55	48310	Diabetes	23,000

Data Owner

Masked Microdata

Age	Zip	Diagnosis	Income
44	48202	AIDS	17,000
44	48202	AIDS	68,000
44	48201	Asthma	80,000
55	48310	Asthma	55,000
55	48310	Diabetes	23,000

External Information

Name	SSN	Age	Zip
Alice	123456789	44	48202
Charley	232345656	44	48201
Dave	333333333	55	48310

Intruder

Identity Disclosure:

Charlie is the third record

Attribute Disclosure:

Alice has AIDS

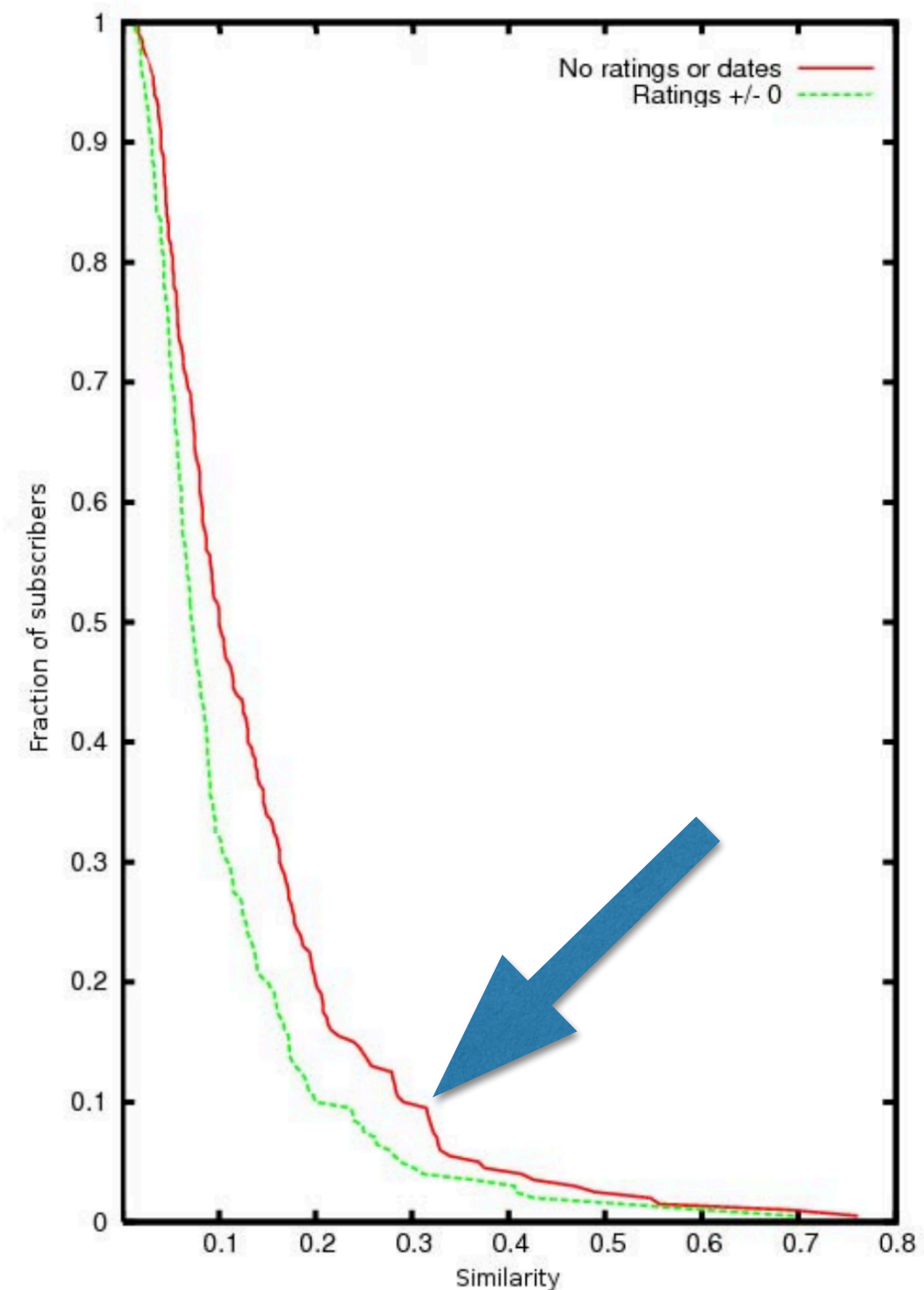
Quasi-Identificadores e Re-Identificação

- O valor de certos atributos (combinados) podem permitir a re-identificação de indivíduos — esses atributos designam-se por **quasi-identificadores**
- e.g. (género + cod. postal + data nascimento) permite identificar cerca de 85% dos indivíduos
- Identificadores; quasi-identificadores e atributos confidenciais

RecID	Name	SSN	Age	State	Diagnosis	Income	Billing
1	John Wayne	123456789	44	MI	AIDS	45,500	1,200
2	Mary Gore	323232323	44	MI	Asthma	37,900	2,500
3	John Banks	232345656	55	MI	AIDS	67,000	3,000
4	Jesse Casey	333333333	44	MI	Asthma	21,000	1,000
5	Jack Stone	444444444	55	MI	Asthma	90,000	900
6	Mike Kopi	666666666	45	MI	Diabetes	48,000	750
7	Angela Simms	777777777	25	IN	Diabetes	49,000	1,200
8	Nike Wood	888888888	35	MI	AIDS	66,000	2,200
9	Mikhail Aaron	999999999	55	MI	AIDS	69,000	4,200
10	Sam Pall	100000000	45	MI	Tuberculosis	34,000	3,100

Anonimização: Netflix Prize

- Em 2006, Netflix partilhou 35.000 ratings de filmes anonimizados: utilizadores pseudonimizados, alguns ratings removidos
- Utilizando informação externa (ratings IMDb), Narayanan e Shmatikov (Texas 2008), conseguiram re-identificar alguns utilizadores
- Apenas 8 ratings de filmes permitiam identificar 99% dos utilizadores



K-anonymity

- Objectivo é que cada combinação de valores de quasi-identificadores resulte numa colecção de, pelo menos, k registos
- Assim, a informação de cada indivíduo de uma BD publicada não pode ser distinguida de, pelo menos, outros $k-1$ indivíduos cuja informação também está incluída na BD
- Existem diferentes estratégias/algoritmos para realizar a “sanitização” de dados por forma a cumprir os requisitos de k-anonymity

K-anonymity é suficiente para garantir privacidade?

- Critérios de k-anonymity não impedem que certos atributos sensíveis possam ser revelados
- Problema deve-se ao facto que os grupos de registos de certas combinação de quasi-idens podem não ter “diversidade” suficiente
- $k = 4$

	Non-Sensitive			Sensitive
	Zip Code	Age	Nationality	Condition
1	130**	< 30	*	Heart Disease
2	130**	< 30	*	Heart Disease
3	130**	< 30	*	Viral Infection
4	130**	< 30	*	Viral Infection
5	1485*	≥ 40	*	Cancer
6	1485*	≥ 40	*	Heart Disease
7	1485*	≥ 40	*	Viral Infection
8	1485*	≥ 40	*	Viral Infection
9	130**	3*	*	Cancer
10	130**	3*	*	Cancer
11	130**	3*	*	Cancer
12	130**	3*	*	Cancer

l-diversity

- Refinamento da noção de k-anonymity que força a que cada grupo esteja representado com, pelo menos, l valores distintos nos atributos sensíveis

- No entanto, permanecem problemas:

- não considera a “semântica” dos atributos
- pouca entropia nos conjuntos resultantes

- $k = 3, l = 3$

Similarity Attack

Bob	
Zip	Age
47678	27

Conclusion

1. Bob's salary is in [20k,40k], which is relative low.
2. Bob has some stomach-related disease.

A 3-diverse patient table

Zipcode	Age	Salary	Disease
476**	2*	20K	Gastric Ulcer
476**	2*	30K	Gastritis
476**	2*	40K	Stomach Cancer
4790*	≥40	50K	Gastritis
4790*	≥40	100K	Flu
4790*	≥40	70K	Bronchitis
476**	3*	60K	Bronchitis
476**	3*	80K	Pneumonia
476**	3*	90K	Stomach Cancer

Sobre os métodos de anonimização

- Área de investigação extremamente activa nos últimos anos, tendo conduzido a uma enorme quantidade de algoritmos/critérios de anonimização
- Noção de quasi-identificadores é crítica para as garantias pretendidas, mas é em grande medida definida apenas informalmente
- Natureza sintáctica dos métodos conduz à possibilidade de ataques quando se explora conhecimento auxiliar sobre “semântica” dos atributos (existem no entanto métodos que procuram ultrapassar esta limitação... e.g. t-closeness)

Discriminação de “poucos”

- No Direito, existe o *princípio básico da não discriminação*
- “*É proibida a discriminação em razão, designadamente, do sexo, raça, cor ou origem étnica ou social, características genéticas, língua, religião ou convicções, opiniões políticas ou outras, pertença a uma minoria nacional, riqueza, nascimento, deficiência, idade ou orientação sexual*” (Art 6º Tratado União Europeia)
- No entanto são as minorias aquelas que mais têm a perder com violações de privacidade, particularmente com técnicas de anonimização.

Uma caracterização semântica da privacidade dos dados

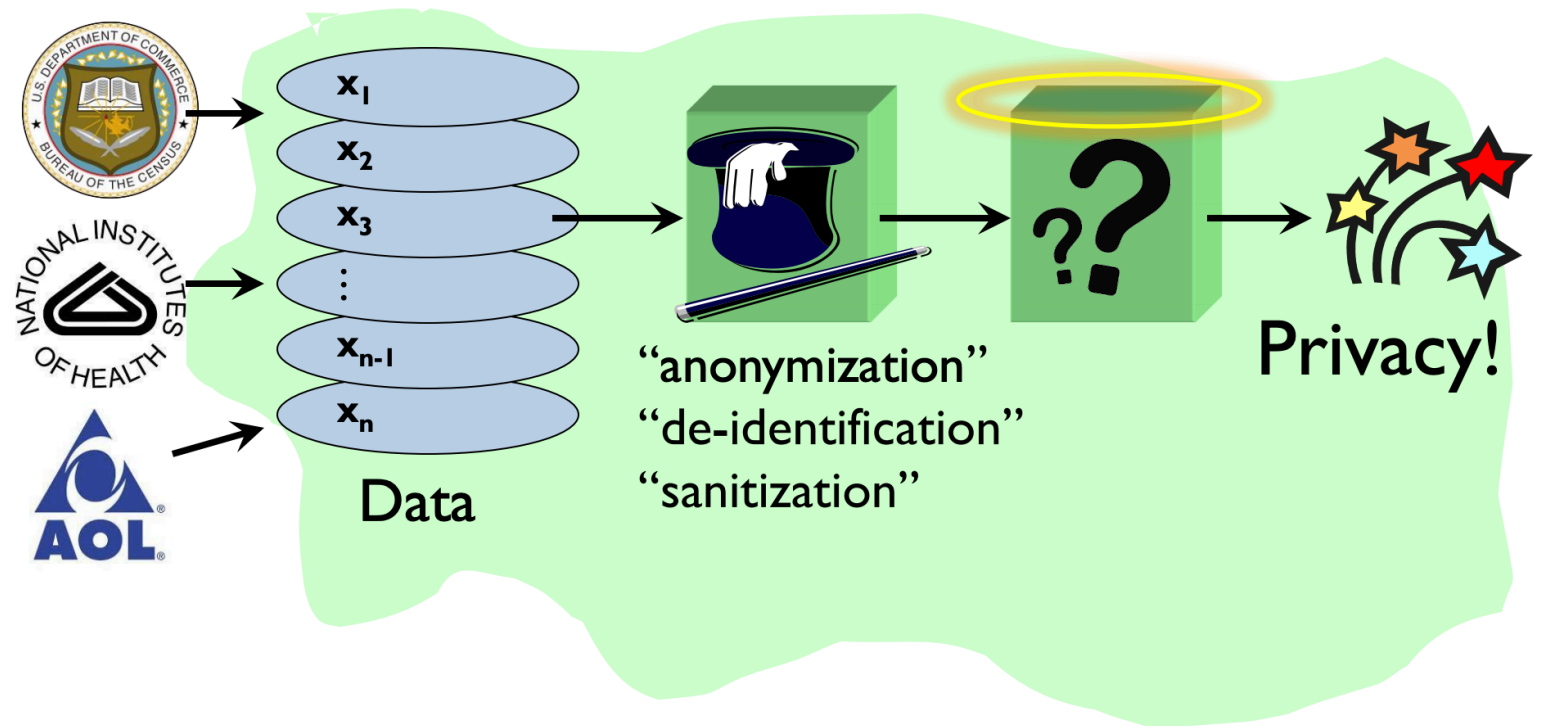
- *“Anything that can be learned about a respondent from the statistical database can be learned without access to the database”* (Dalenius, 1977)
- Caracterização “em linha” com definições muito bem sucedidas na área da teoria da criptografia
- Infelizmente, Dwork & Naor [2006] demonstraram que é inatingível

Resultado de Impossibilidade!

- BD: alturas dos indivíduos de uma amostra significativa da população da Lituânia
- Informação auxiliar: “*Terry Gross é 5cm mais baixa do que a média das mulheres Lituanas*”
- Alguém sem acesso à BD não tem forma de saber a altura de Terry Gross
- Com acesso à BD, altura de Terry Gross é descoberta independentemente de o seu registo estar ou não nessa BD.

Privacidade: Uma propriedade da computação

- *“Privacy is a property of the informational relationship between the input and output, not a property of the output alone”*
(Harvard 2018)
- *Resultado conhecido na literatura de criptografia*
- *Aponta para a necessidade de uma caracterização semântica da computação*



Differential-Privacy

- Dificuldades com definição semântica da privacidade conduziu a busca de definições alternativas
- Uma das mais bem sucedidas é a noção de Differential-Privacy (DP)
 - procura limitar a influência de um qualquer registo na BD
 - formalmente, limita a diferença nos resultados observáveis de uma computação quando se insere ou remove um registo particular

Anonimização usando DP

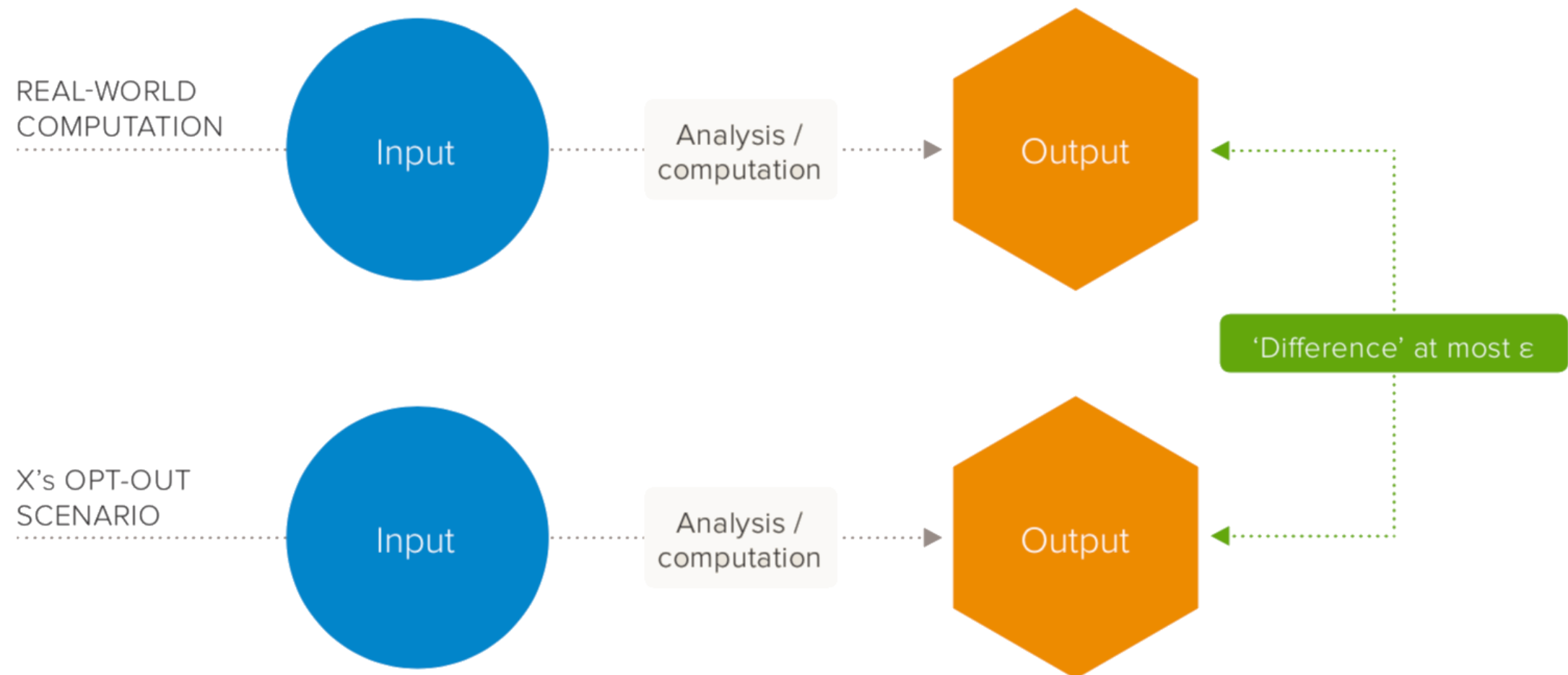
- Ana e Rui utilizam um sistema de processamento estatístico dados fornecido pela escola, baseado em DP
- Ana publica em Janeiro: “A escola tem 3005 alunos, dos quais aproximadamente 202 recebem apoio social”
- Rui publica em Março: “Na escola, aproximadamente 203 alunos numa amostra de 3006 recebem apoio social”
- Eva questiona-se: “Se o João Silva entrou na escola em Fevereiro, será que recebe apoio social?”
- O risco de violação da privacidade do João Silva é mais reduzido

O que DP não protege

- Eva sabe: “*João gosta de beber vinho ao jantar*”
- Estudo independente: “*Beber vinho está relacionado com um certo tipo de cancro*”
- Eva descobre: “*João tem maior risco de contrair cancro*”
- Eva descobre mais informação privada sobre o João, quer ele participe no estudo ou não.
Inevitável?

Caracterização de DP

- Uma computação é dita *differentially-private* se, para cada registo X:



- ϵ é o chamado *budget* de privacidade

O que DP protege

- Ana tem um seguro de vida que, pela sua idade, estima que tem 1% de chance de morrer.
- Estudo feito pela DGS com recurso a voluntários revela que os Portugueses com a idade da Ana têm em média 2% de chance de morrer.
- Se a Ana não participar no estudo, a sua seguradora pode decidir atualizar o valor do seu seguro para 2%.
- Se a Ana participar no estudo, a DGS descobre que tem uma doença terminal com 95% de chances de morrer.
- Se o estudo for realizado com recurso a DP ($\varepsilon = 0.01$), então a média apresentada só pode ser no máximo $2\% * (1 + \varepsilon) = 2.02\%$

DP é incremental

- Mais tarde, a DGS decide realizar outro estudo com a mesma base de dados, e decide utilizar novamente DP ($\varepsilon_2 = 0.02$)
- Depois de divulgado o estudo, a seguradora estima que a chance de morrer da Ana é agora de 3%
- Quer a Ana participe ou não no estudo, a sua chance de morrer estimada pela seguradora não passará de $3\% * (1 + \varepsilon_1 + \varepsilon_2) = 3\% * (1 + 0.01 + 0.02) = 3.09\%$

DP é incremental

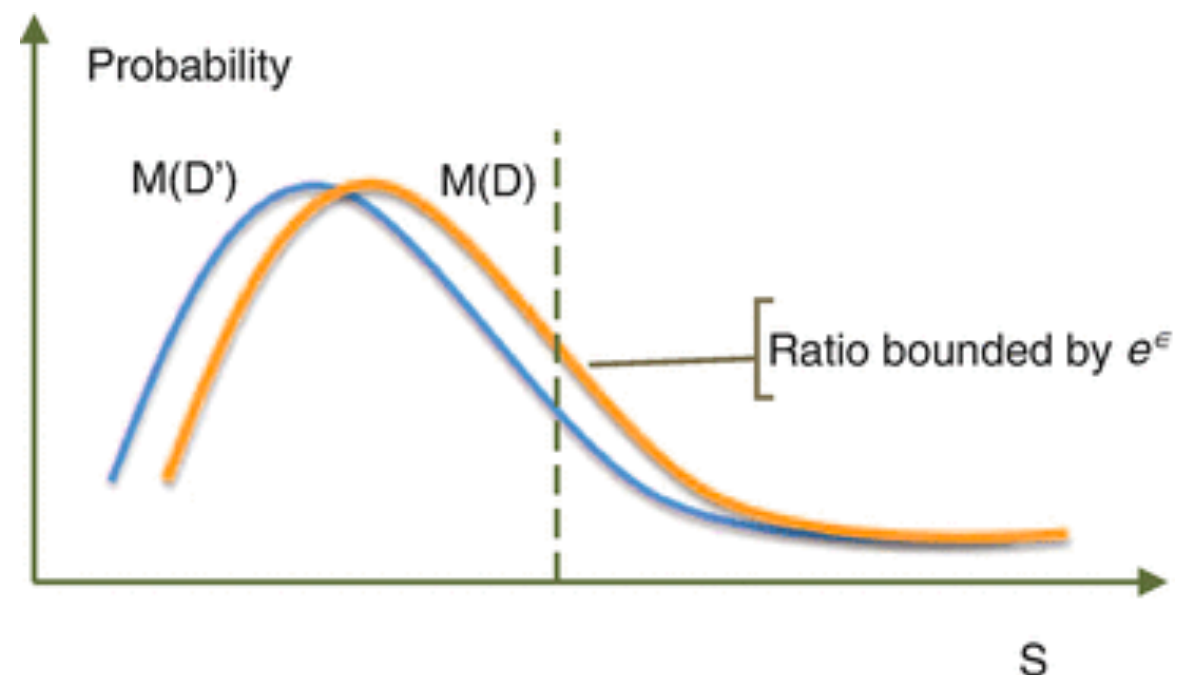
- No próximo ano, a DGS decide realizar um novo estudo com novos voluntários, e utilizando novamente DP ($\varepsilon_3 = 0.01$)
- Depois de divulgado o estudo, a seguradora estima que a chance de morrer da Ana é agora de 4%
- Quer a Ana participe ou não no estudo, a sua chance de morrer estimada pela seguradora não passará de $4\% * (1 + \max(\varepsilon_{12}, \varepsilon_3)) = 4\% * (1 + \max(0.03, 0.01)) = 4.12\%$

Caracterização de DP

- DP formaliza a intuição com uma definição matemática.
- Sejam D_1 e D_2 duas BD diferindo apenas num único registo; $\mathcal{K}$ uma computação (probabilística) e $S \subseteq \text{Range}(\mathcal{K})$. $\mathcal{K}$ fornece ϵ -differential privacy quando:

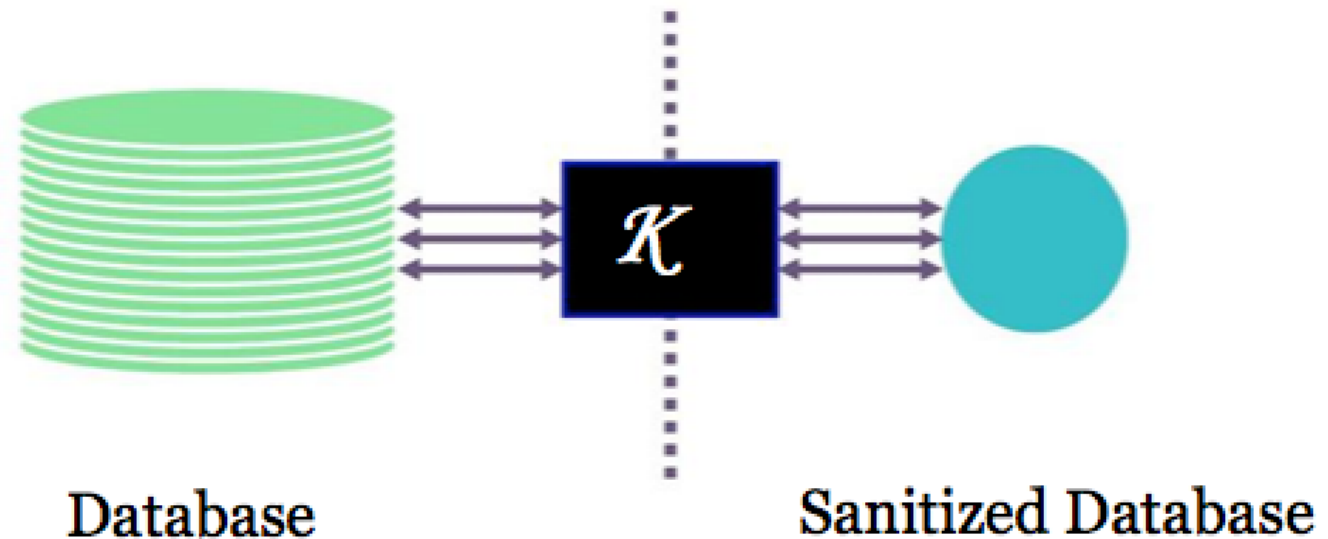
$$\Pr[\mathcal{K}(D_1) \in S] \leq \exp(\epsilon) \times \Pr[\mathcal{K}(D_2) \in S]$$

- $\epsilon = 0$
privacidade máxima
precisão mínima
- ...

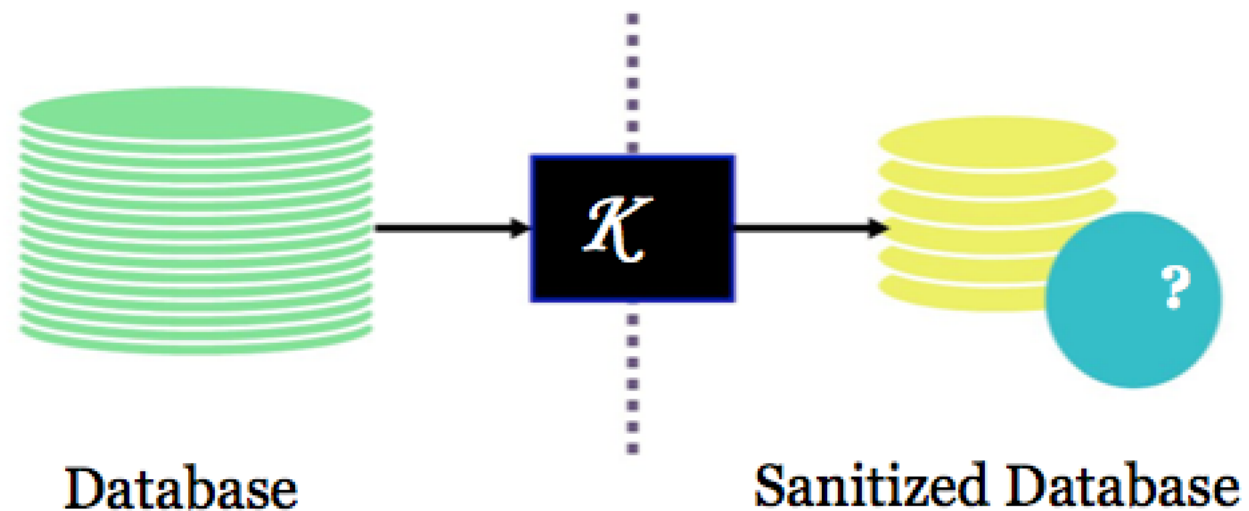


Arquitecturas DP

- Interactiva:

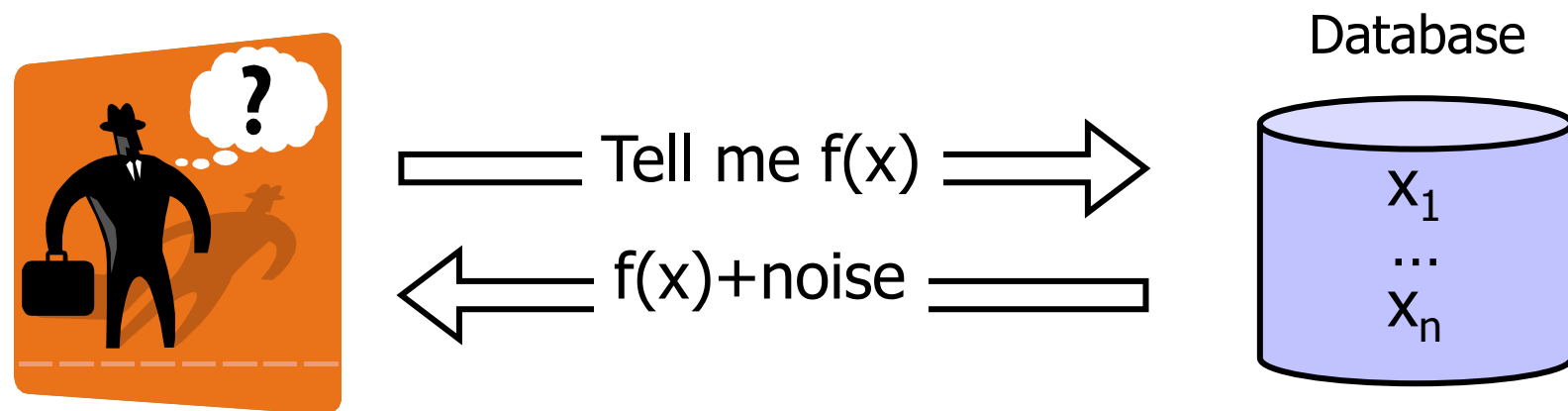


- Não-interactiva:



Como atingir DP?

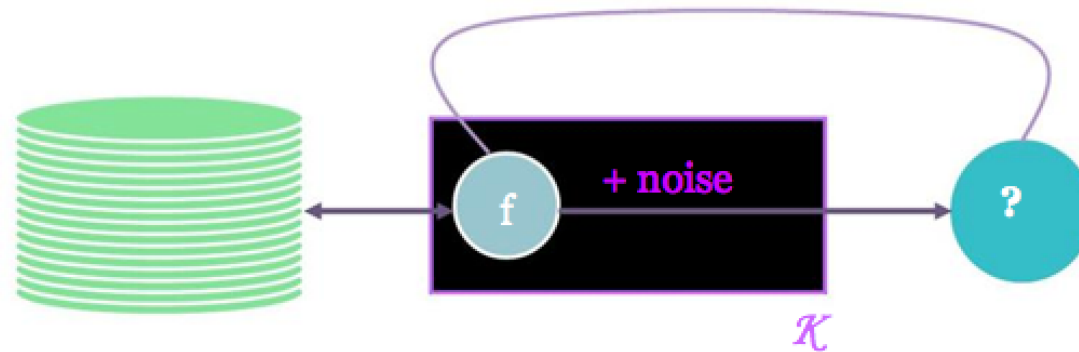
- Estratégia:



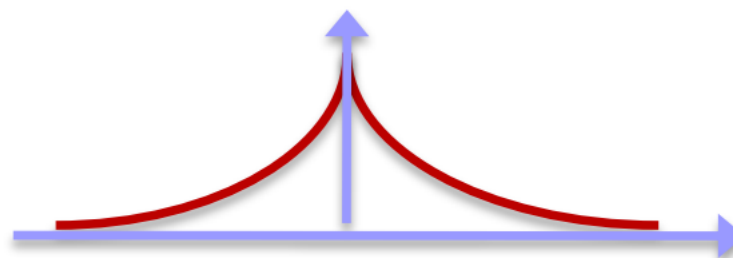
- Nível de ruído deve depender:
 - do limite ε pretendido
 - da sensibilidade da computação f
- Sensibilidade da query = impacto de um indivíduo

$$\Delta f = \max \|f(D_1) - f(D_2)\|_1$$

DP para *queries* numéricas



- $f: \text{DB} \rightarrow \mathbb{R}_d$
 $\mathcal{K}(f, \text{DB}) = f(\text{DB}) + [\text{Noise}]_d$
- Eg, $f = \text{Count}(P, \text{DB}) = \# \text{ rows in DB with Property } P$
- Teorema: $\mathcal{K}$ é differential-private quando nível de ruído é dado por $\text{Lap}(\Delta f/\epsilon)$



Exemplo de aplicação

ID	Claim ('000\$)	ID	Claim ('000\$)
1	9.91	7	10.63
2	9.16	8	12.54
3	10.59	9	9.29
4	11.27	10	8.92
5	10.50	11	20
6	11.89	12	8.55
...	...	...	...

Query : Average claim

Aux input : 12 entries

$\epsilon = 1 \rightarrow$ hide me
among 1200 people

- $\Delta f = 11.10 - 10.29 = 0.89$
[obs: média é uma função pouco sensível]
- Ruído: $\text{Lap}(\Delta f/\epsilon) = \text{Lap}(.89) = 1.31$
[obs: resposta aprox. ± 1.31]
- Conclusão: resposta c/ grande utilidade

Exemplo de aplicação

ID	Claim ('000\$)	ID	Claim ('000\$)
1	9.91	7	10.63
2	9.16	8	12.54
3	10.59	9	9.29
4	11.27	10	8.92
5	10.50	11	20
6	11.89	12	8.55
...	...	...	...

Query : max claim

Aux input : 12 entries

$\epsilon = 1 \rightarrow$ hide me
among 1200 people

- $\Delta f = 20 - 12.54 = 7.46$
[obs: máximo é uma função muito sensível]
- Ruído: $\text{Lap}(\Delta f/\epsilon) = \text{Lap}(7.46) = 113.1$
[obs: resposta aprox. ± 113.1]
- Conclusão: resposta completamente inútil!!!

Conclusões

- DP oferece uma base teórica sólida sobre o nível de privacidade que é possível estabelecer para determinada família de computações ou *queries*
- Existem linguagens de *query* específicas que incorporam já esse mecanismo (e.g. Privacy Integrated Query — Pinq, da Microsoft)
 - <http://blog.myplaceinthecrowd.org/tag/pinq-demo/>
- Já começam a aparecer exemplos reais, e.g. o US Census Bureau está a utilizar DP para o seu próximo censo de 2020
 - https://www.census.gov/about/policies/privacy/statistical_safeguards/disclosure-avoidance-2020-census.html
- Um aspecto atractivo da DP é que é possível raciocinar incrementalmente sobre a (perda de) privacidade
- Existem numerosas variantes do mecanismo base (e.g. para cobrir *queries* distintas; etc.)

Saber mais

- Harvard Privacy Tools Project: <https://privacytools.seas.harvard.edu/courses-educational-materials>
- Google TensorFlow: https://www.youtube.com/watch?v=fCxp_IHo5ek
- Algumas palestras não técnicas:
 - <https://www.savjee.be/videos/simply-explained/differential-privacy/>
 - <https://www.youtube.com/watch?v=IFZwD0N-k3s>